

Phishing Incident Report

Mutawa Marine Services Impersonation

Author: Leonard Okyere Afeke

Date: March 25, 2026

This report is based entirely on publicly available information (OSINT). No scanning, exploitation, or interaction with live systems occurred.

Executive Summary

A phishing email impersonating Mutawa Marine Services was delivered to the recipient with a malicious RAR archive disguised as a PDF receipt. The attachment contained a Trojan Downloader, confirmed by VirusTotal (46/63 detections) and Hybrid Analysis (Threat Score 100/100). The email did not originate from the legitimate organization and instead came from a Hostwinds VPS, indicating clear domain spoofing.

The malware exhibited outbound encrypted communication (SSL/TLS) and TOR-related behavior, consistent with downloader malware attempting to contact remote infrastructure for follow-on payload delivery. VirusTotal's Relations graph linked the payload to multiple phishing emails and ZIP archives across 2025, suggesting the sample is part of a broader commodity malware distribution campaign rather than a targeted attack.

No evidence indicates that the threat actor had specific interest in the recipient. The infrastructure, malware type, and delivery method all align with low-sophistication cybercrime activity aimed at establishing initial access for secondary payload deployment such as credential stealers, RATs, or ransomware.

1 Incident Narrative

1.1 Initial Delivery

The phishing email impersonated Mutawa Marine Services and claimed to provide a shipping receipt. The attachment, named to resemble a PDF, was actually a RAR archive containing a disguised executable. This social engineering approach is consistent with commodity phishing campaigns that rely on user interaction to initiate malware execution.

1.2 Email Infrastructure Analysis

Header analysis revealed that the email did not originate from the legitimate mutawamarine.com domain. Instead, it was sent from a Hostwinds VPS (192.119.71.157), a low-cost hosting provider frequently used for disposable phishing infrastructure.

Authentication checks showed:

- SPF: Fail
- DKIM: None
- DMARC: Fail

The Reply-To address pointed to a mail.com account, a tactic commonly used to redirect victim responses away from the impersonated organization.

1.3 Malware Analysis

The attached archive (SWT_ #09674321____PDF___.CAB) contained a .NET executable (SWT_ #09674321__PDF_.com) masquerading as a PDF file. VirusTotal identified the payload as malicious, with 46/63 vendors flagging the archive and 60/72 flagging the extracted executable.

VirusTotal Relations linked the sample to multiple phishing emails and ZIP archives submitted throughout 2025, indicating a broad, ongoing distribution campaign.

Hybrid Analysis classified the payload as a Trojan Downloader (Threat Score 100/100). Behavioral observations included:

- Outbound SSL/TLS traffic
- TOR-related communication patterns
- Multi-process execution

No persistence, privilege escalation, or lateral movement behaviors were observed.

1.4 Assessment

The phishing email and associated malware reflect low-sophistication cybercrime activity aimed at establishing a foothold on the victim's system. The combination of spoofed sender identity, public email reply-to address, VPS-based sending infrastructure, and commodity downloader malware aligns with financially motivated threat actors distributing malware at scale.

2 Indicators of Compromise (IOCs)

Category	Indicator	Description
Sender IP	192.119.71.157	Hostwinds VPS; origin of spoofed phishing email
Spoofed Domain	mutawamarine.com	Legitimate business domain impersonated
Reply-To Domain	mail.com	Public email provider used for redirection
Attachment Name	SWT_#09674321_...PDF...CAB	Malicious RAR/CAB archive disguised as PDF
Extracted Payload	SWT_#09674321_...PDF.com	Malicious .NET executable
SHA-256 (Archive)	2e91c533615a9bb8929ac4bb76707b2444597ce063d84a4b33525e25074fff3f	Hash of malicious archive
SHA-256 (Payload)	05261f5a64f81a34fdde66cc82b573773e5dfa3bb5c3ccbfe2d0eef0e9d7b6c9	Hash of Trojan Downloader
Email Authentication	SPF: Fail; DKIM: None; DMARC: Fail	Confirms spoofing
MX Record	mutawamarine-com.mail.protection.outlook.com	Legitimate Microsoft 365 mail host
Nameservers	DNS1.STABLETRANSIT.COM / DNS2.STABLETRANSIT.COM	Rackspace
Behavioral Indicators	SSL/TLS traffic; TOR activity; Multi-process execution	Downloader behavior

3 Recommendations

3.1 Email Security Controls

- Enforce SPF, DKIM, and DMARC validation.
- Quarantine or reject messages failing DMARC alignment.
- Block executable content inside compressed archives.
- Enable attachment sandboxing.

3.2 User Awareness and Training

- Reinforce phishing awareness around unexpected receipts.
- Encourage reporting of suspicious emails.

3.3 Endpoint Protection

- Block unknown or unsigned executables.
- Detect downloader behavior and multi-process spawning.
- Alert on suspicious outbound encrypted traffic.

3.4 Network Security

- Block TOR exit nodes and known malicious IPs.
- Restrict traffic to unused VPS providers.
- Enable SSL/TLS inspection where appropriate.

3.5 Incident Response Readiness

- Maintain phishing and malware containment playbooks.
- Retain logs for at least 90 days.

3.6 IOC Deployment

- Push IOCs to SIEM, EDR, firewall, and email gateway.
- Conduct threat hunting for related activity.

Appendix A — Methodology and Source

This report is based entirely on publicly available information (OSINT). No scanning, exploitation, or interaction with live systems occurred.

The phishing email sample (`challenge.eml`) was obtained from the TryHackMe training environment “*The Greenholt Phish*”. All analysis was performed on a controlled, sandboxed copy of the file.